

EVIDENCE REPORT

Critical Data Exposure on the Client Server

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Tester	Blessing Princess Augustine
Batch / Week	B083 — Week 4
Date	01 October 2026
Authorisation	Written Permission: GRANTED
Deliverable	Full documented evidence of the exposure + readable summary of confidential data uncovered

CRITICAL SEVERITY — Unauthenticated public access to a full database backup containing staff salaries, national IDs and shareholder records.

□

SECTION 1 — EVIDENCE OF THE EXPOSURE

The exposure was discovered through a chain of six reconnaissance steps. Each step is documented below with the exact command used, the output received, and a screenshot as proof.

Step 1 — Nikto Scan Flags /old/ Directory

During active web scanning, Nikto identified directory indexing enabled on three sensitive paths, including /old/.

nikto -h https://medirozahospital.com

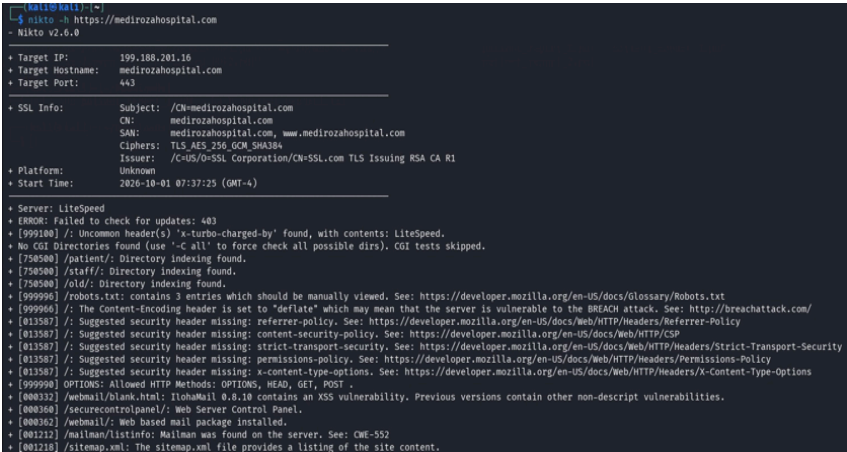


Figure 1 — Nikto scan output: /old/ directory indexing found (line 3), alongside /patient/ and /staff/

[750500] /old/: Directory indexing found.

Step 2 — robots.txt Confirms the Path

The robots.txt file explicitly listed /old/ as a disallowed path. Rather than hiding it, this acted as a

public map of sensitive directories for any attacker.

```
curl https://medirozahospital.com/robots.txt
```



```
kali@kali: ~  
Session Actions Edit View Help  
~  
$ curl https://medirozahospital.com/robots.txt  
# robots.txt  
User-agent: *  
Disallow: /patient/  
Disallow: /staff/  
Disallow: /old/  
  
Sitemap: https://medirozahospital.com/sitemap.xml
```

Figure 2 — robots.txt disclosing Disallow: /patient/, /staff/, /old/

Step 3 — Directory Listing Reveals Database Backup

Browsing directly to /old/ returned a full directory listing showing a single file: a MySQL database backup.

```
curl https://medirozahospital.com/old/
```



```
kali@kali: ~  
$ curl https://medirozahospital.com/old/  
<!DOCTYPE html><html><head><meta http-equiv="Content-type" content="text/html; charset=UTF-8" /><meta name="viewport" content="width=device-width, initial-sc  
" href="/_autoindex/assets/css/autoindex.css" /><script src="/_autoindex/assets/js/tablesort.js"></script><script src="/_autoindex/assets/js/tablesort.number  
td/></title><style>@media (prefers-color-scheme:dark){body{background-color:#000!important}}</style></head><body><div class="content"><h1 style="color: #555;"  
<div id="table-list"><table id="table-content"><thead class="t-header"><tr><th class="colname" aria-sort="ascending"><a class="name" href="#" onclick="ret  
ss="colname" data-sort-method="number"><a href="#">MA" onclick="return false">Last Modified</a></th><th class="colname" data-sort-method="number"><a href="#">PS  
</a></th></tr></thead>  
<tr data-sort-method="none"><td><a href="#">Parent Directory</a></td><td></td><td></td><t  
<tr><td data-sort="mediroza_db_backup_2019.sql"><a href="/old/mediroza_db_backup_2019.sql"><td data-sort="1788487331">2026-09-04 02:02</td><td data-sort="6346">7k</td></tr>  
</table></div>  
<address>Proudly Served by LiteSpeed Web Server at medirozahospital.com Port 443</address></div><script>new TableSort(document.getElementById("table-content"
```

Figure 3 — curl /old/: directory listing confirms mediroza_db_backup_2019.sql (6,346 bytes)

Step 4 — Direct Browser Access (No Authentication)

The file URL was entered directly into the browser. It loaded instantly with no login, token, or session required — confirming zero access controls on the resource.

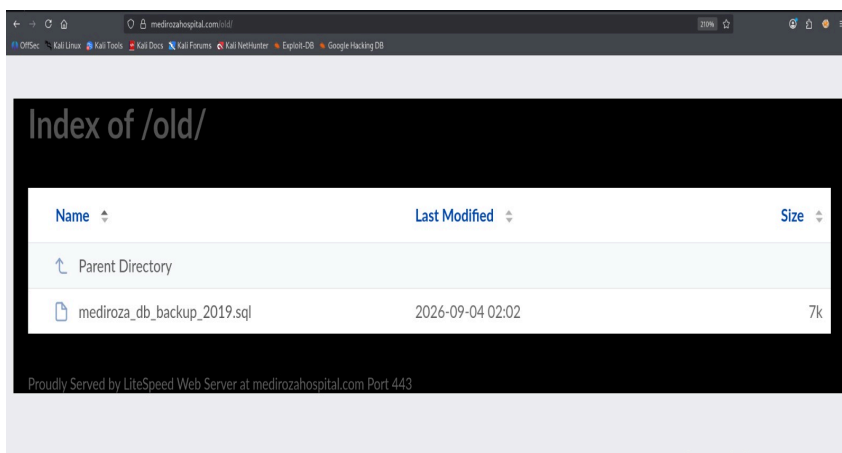


Figure 4 — Browser confirms Index of /old/ with mediroza_db_backup_2019.sql accessible at a public URL

Step 5 — File Downloaded via wget

The database backup was downloaded using wget. The server returned HTTP 200 OK, confirming unauthenticated download was possible.

```
wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```

```
(kali@kali) ~/Downloads
$ wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
--2026-10-01 15:45:46-- https://medirozahospital.com/old/mediroza_db_backup_2019.sql
Resolving medirozahospital.com (medirozahospital.com)... 199.188.201.16
Connecting to medirozahospital.com (medirozahospital.com):199.188.201.16:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 6346 (6.2K) [text/x-sql]
Saving to: 'mediroza_db_backup_2019.sql'

mediroza_db_backup_2019.sql 100% |=====|
2026-10-01 15:45:47 (148 MB/s) - 'mediroza_db_backup_2019.sql' saved [6346/6346]
```

Figure 5 — wget: HTTP 200 OK, 6,346 bytes downloaded at 148 MB/s — no credentials required

Step 6 — Database Structure Confirmed

grep commands confirmed two sensitive tables inside the backup: staff (containing salaries and national IDs) and shareholders.

```
grep -i "CREATE TABLE" mediroza_db_backup_2019.sql
grep -i "salary" mediroza_db_backup_2019.sql
grep -i "shareholder" mediroza_db_backup_2019.sql
```

The database contained an internal WARNING comment: "contains confidential staff and shareholder records"

□

SECTION 2 — READABLE SUMMARY OF CONFIDENTIAL DATA UNCOVERED

2.1 Staff Salary Records — 30 Employees Exposed

Data exposed: full names, job titles, departments, email addresses, phone numbers, national ID numbers, monthly salaries (ZAR), and employment dates.

```
-- LOCK TABLES 'staff' WRITE;
INSERT INTO 'staff' ('id', 'full_name', 'job_title', 'department', 'email', 'phone', 'national_id', 'monthly_salary_zar', 'date_joined') VALUES
(1, 'Dr. Rajesh Naidoo', 'Chief Pathologist', 'Diagnostics Lab', 'r.naidoo@medirozahospital.com', '+27 82 101 2087', '85021013011081', 138000, '2009-03-16'),
(2, 'Sarah Botha', 'Chief Financial Officer', 'Finance', 's.botha@medirozahospital.com', '+27 82 102 2014', '85031023022082', 152000, '2011-07-01'),
(3, 'Dr. Johan van der Merwe', 'Medical Director', 'Management', 'j.merwe@medirozahospital.com', '+27 82 103 2021', '85041033033083', 160000, '2007-01-22'),
(4, 'Dr. Anita Maicker', 'Consultant Cardiologist', 'Cardiology', 'a.maicker@medirozahospital.com', '+27 82 104 2028', '85051043044084', 112000, '2012-09-10'),
(5, 'Dr. Ahmed Kara', 'Consultant Physician', 'Internal Medicine', 'a.kara@medirozahospital.com', '+27 82 105 2035', '85061053055085', 120000, '2013-02-18'),
(6, 'Dr. Yusuf Cassim', 'Senior Registrar', 'Emergency & Trauma', 'y.cassim@medirozahospital.com', '+27 82 106 2042', '85071063066086', 74000, '2018-05-04'),
(7, 'Michael Roberts', 'HR Director', 'Human Resources', 'm.roberts@medirozahospital.com', '+27 82 107 2049', '85081073077087', 96000, '2010-11-15'),
(8, 'Susan Pretorius', 'HR Officer', 'Human Resources', 's.pretorius@medirozahospital.com', '+27 82 108 2056', '85091083088088', 32000, '2016-08-23'),
(9, 'Jameel Malik', 'IT Systems Administrator', 'IT', 'j.malik@medirozahospital.com', '+27 82 109 2063', '85101093099089', 58000, '2015-04-12'),
(10, 'Thabo Molefe', 'Network Engineer', 'IT', 't.molefe@medirozahospital.com', '+27 82 110 2070', '85111103110081', 46000, '2017-10-02'),
(11, 'Nomvula Khumalo', 'Registered Nurse', 'Emergency & Trauma', 'n.khumalo@medirozahospital.com', '+27 82 111 2077', '85121113121082', 34000, '2016-01-19'),
(12, 'Lerato Mopena', 'Registered Nurse', 'Pediatrics', 'l.mopena@medirozahospital.com', '+27 82 112 2084', '85011123132083', 33000, '2017-06-07'),
(13, 'Bongani Ndlovu', 'Registered Nurse', 'Cardiology', 'b.ndlovu@medirozahospital.com', '+27 82 113 2091', '85021133143084', 35000, '2015-12-01'),
(14, 'Zanele Mahlangu', 'Nursing Sister', 'Theatre', 'z.mahlangu@medirozahospital.com', '+27 82 114 2098', '85031143154085', 42000, '2013-03-25'),
(15, 'Kgabo Sithole', 'Pharmacist', 'Pharmacy', 'k.sithole@medirozahospital.com', '+27 82 115 2105', '85041153165086', 61000, '2014-09-08'),
(16, 'Naledi Zulu', 'Pharmacy Assistant', 'Pharmacy', 'n.zulu@medirozahospital.com', '+27 82 116 2112', '85051163176087', 26000, '2019-02-14'),
(17, 'Themba Nkosi', 'Radiographer', 'Radiology', 't.nkosi@medirozahospital.com', '+27 82 117 2119', '85061173187088', 44000, '2016-07-30'),
(18, 'Patene Radebe', 'Radiographer', 'Radiology', 'p.radebe@medirozahospital.com', '+27 82 118 2126', '85071183198089', 43000, '2017-04-11'),
(19, 'Deepak Pillay', 'Lab Technologist', 'Diagnostics Lab', 'd.pillay@medirozahospital.com', '+27 82 119 2133', '85081193209081', 41000, '2015-05-20'),
(20, 'Kavitha Govender', 'Lab Technician', 'Diagnostics Lab', 'k.govender@medirozahospital.com', '+27 82 120 2140', '85091203220082', 35000, '2018-08-06'),
(21, 'Dr. Suresh Moodley', 'Consultant Radiologist', 'Radiology', 's.moodley@medirozahospital.com', '+27 82 121 2147', '85101213231083', 130000, '2012-02-28'),
(22, 'Dr. Fatima Patel', 'Pediatrician', 'Pediatrics', 'f.patel@medirozahospital.com', '+27 82 122 2154', '85111223242084', 110000, '2013-10-17'),
(23, 'Nisha Singh', 'Physiotherapist', 'Rehabilitation', 'n.singh@medirozahospital.com', '+27 82 123 2161', '85121233253085', 48000, '2016-11-09'),
(24, 'Dr. Vikram Chetty', 'Anaesthetist', 'Theatre', 'v.chetty@medirozahospital.com', '+27 82 124 2168', '8511243264086', 135000, '2011-06-13'),
(25, 'David Smith', 'Facilities Manager', 'Operations', 'd.smith@medirozahospital.com', '+27 82 125 2175', '85021253275087', 52000, '2014-01-27'),
(26, 'Karen O'Connor', 'Billing Administrator', 'Finance', 'k.oconnor@medirozahospital.com', '+27 82 126 2182', '85031263286088', 29000, '2018-03-19'),
(27, 'James Wilson', 'Security Supervisor', 'Operations', 'j.wilson@medirozahospital.com', '+27 82 127 2189', '85041273297089', 27000, '2019-09-02'),
(28, 'Linda Fourie', 'Receptionist', 'Front Office', 'l.fourie@medirozahospital.com', '+27 82 128 2196', '85051283308081', 19000, '2020-02-10'),
(29, 'Peter van Wyk', 'Procurement Officer', 'Supply Chain', 'p.vwyk@medirozahospital.com', '+27 82 129 2203', '85061293319082', 38000, '2015-08-24'),
(30, 'Andile Mbeki', 'Ward Clerk', 'Administration', 'a.mbeki@medirozahospital.com', '+27 82 130 2210', '85071303330083', 21000, '2019-11-05');
UNLOCK TABLES;
```

Figure 6 — mediroza_db_backup_2019.sql: Full staff table showing all 30 employee records including salaries and national IDs

Summary of salary data extracted:

	Full Name	Job Title	Department	Monthly Salary (ZAR)
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	138,000
2	Sarah Botha	Chief Financial	Finance	152,000

		Officer		
3	Dr. Johan van der Merwe	Medical Director	Management	160,000
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	132,000
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	128,000
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	74,000
7	Michael Roberts	HR Director	Human Resources	96,000
8	Susan Pretorius	HR Officer	Human Resources	32,000
9	Jameel Malik	IT Systems Administrator	IT	58,000
10	Thabo Molefe	Network Engineer	IT	46,000
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	34,000
12	Lerato Mokoena	Registered Nurse	Pediatrics	33,000
13	Bongani Ndlovu	Registered Nurse	Cardiology	35,000
14	Zanele Mahlangu	Nursing Sister	Theatre	42,000
15	Kagiso Sithole	Pharmacist	Pharmacy	61,000
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	26,000
17	Themba Nkosi	Radiographer	Radiology	44,000
18	Palesa Radebe	Radiographer	Radiology	43,000
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	41,000
20	Kavitha Govender	Lab Technician	Diagnostics Lab	35,000
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	130,000
22	Dr. Fatima Patel	Paediatrician	Pediatrics	118,000
23	Nisha Singh	Physiotherapist	Rehabilitation	48,000
24	Dr. Vikram Chetty	Anaesthetist	Theatre	135,000
25	David Smith	Facilities Manager	Operations	52,000
26	Karen O'Connor	Billing Administrator	Finance	29,000
27	James Wilson	Security Supervisor	Operations	27,000
28	Linda Fourie	Receptionist	Front Office	27,000
29	Peter van Wyk	Procurement Officer	Supply Chain	38,000
30	Andile Mbeki	Ward Clerk	Administration	21,000

Highest salary	R160,000 — Dr. Johan van der Merwe (Medical Director)
Lowest salary	R21,000 — Andile Mbeki (Ward Clerk)
Total records exposed	30 staff members
Additional data per record	Email, phone number, national ID, employment date
National IDs exposed	All 30 — 13-digit South African ID numbers

□

2.2 Shareholder Register — 10 Records Exposed

Data exposed: shareholder names, share percentage, number of shares held, share class (Ordinary / Preferential).

```
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;
```

Figure 7 — mediroza_db_backup_2019.sql: Full shareholders table showing all 10 shareholder records

	Shareholder Name	Share %	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0%	120,000	Ordinary
4	Reddy Family Trust	11.0%	110,000	Ordinary
5	Thabo Molefe	10.0%	100,000	Ordinary
6	Sarah Botha	9.0%	90,000	Ordinary
7	Dr. Ahmed Kara	8.0%	80,000	Preferential
8	Naledi Zulu	7.0%	70,000	Ordinary
9	Michael Roberts	6.0%	60,000	Ordinary
10	Dr. Vikram Chetty	4.0%	40,000	Preferential

Total shareholders	10
Largest individual shareholder	Dr. Rajesh Naidoo — 18.0% (180,000 shares)
Largest institutional shareholder	Cedar Health Holdings (Pty) Ltd — 15.0%
Preferential shareholders	Dr. Ahmed Kara (8%) and Dr. Vikram Chetty (4%)
Total share capital accounted for	100% of issued share capital

SECTION 3 — IMPACT AND IMMEDIATE REMEDIATION

3.1 Impact of This Exposure

- Personal data breach: 30 employees had full names, national IDs, salaries and contact details exposed — serious violation of POPIA (South Africa's Protection of Personal Information Act)
- Identity theft risk: national IDs combined with contact details give enough for targeted fraud against all 30 employees
- Shareholder exposure: complete share register constitutes insider/confidential corporate information exploitable for financial or competitive advantage
- Staff email format confirmed (e.g. r.naidoo@medirozahospital.com) — enables targeted spear-phishing campaigns against known individuals
- No exploitation skill required — the file was accessible to anyone who visited a public URL

3.2 Root Cause

Misconfiguration	Description
Backup stored in web root	mediroza_db_backup_2019.sql was placed inside the publicly accessible /old/ web directory instead of outside the web root
Directory indexing enabled	LiteSpeed served a browsable listing of /old/, revealing the file's existence

No access controls on file	No authentication, IP restriction, or .htaccess protection prevented direct download
----------------------------	--

3.3 Immediate Actions Required

The database backup is currently publicly accessible. The following actions must be taken immediately.

- IMMEDIATE: Remove mediroza_db_backup_2019.sql from /old/ web directory
- IMMEDIATE: Store all database backups outside the web root (e.g. /var/backups/)
- IMMEDIATE: Disable directory indexing on LiteSpeed for all directories
- SHORT TERM: Audit all files in /old/, /staff/, /patient/ and remove unnecessary items
- SHORT TERM: Assess POPIA breach notification obligations for affected staff
- MEDIUM TERM: Implement backup policy with encryption, access controls, and off-site storage